

Phase 1 — Current System QA Report

Full inspection of the existing single-tenant Rent-a-Car Management System before any SaaS conversion. Sections A to Y. Stabilise this baseline first.

Document type	Phase 1 functional QA, security, and UI/UX inspection
Date	17 September 2026
Scope	Existing codebase only — no implementation in this document
Current state	Single-tenant RedKnot back office on Next.js + Prisma + TiDB + Vercel
Phase 1 goal	Inspect, identify bugs, then later polish UI and create a stable git checkpoint
Out of scope	SaaS, multi-tenancy, companyId, subscriptions, Google OAuth, global blacklist

Answer the four decisions at the end of this PDF in chat before any Phase 1 code changes begin.

Contents

A. Current Architecture	
B. Current Project Structure	
C. Current Database Structure	
D. Current Authentication	
E. Current Role / Permission System	
F. Complete Current Left Sidebar / Navigation Map	
G. Current Business Modules	
H. Current Rental / Hire Workflow	
I. Current Blacklist Functionality	
J. Functional Bugs Found	
K. Security Issues Found	
L. IDOR / Authorization Risks	
M. API / Server Action Issues	
N. Database Issues	
O. Performance Issues	
P. UI/UX Issues	
Q. Deployment Issues	
R. Existing Tests	
S. Tests That Should Be Added	
T. Files That Require Changes	
U. Safe Changes for Phase 1	
V. Changes That Must Wait for SaaS Phase	
W. Future SaaS Architecture Considerations	
X. Potential Breaking Changes	
Y. Recommended Phase 1 Implementation Order	
Questions waiting for your decision	

A. Current Architecture

The live application is a single-tenant back office for one company: RedKnot Rent-a-Car. There is no Company model, no companyId/tenantId, no platform Super Admin dashboard, and no subscription layer. This existing Rent-a-Car Management System is the product that must be preserved. The future SaaS version should be this same business application running for multiple independent companies.

Stack: Next.js 16.3.1 App Router, React 19, TypeScript, Prisma 5.22 to MySQL-compatible TiDB Cloud, NextAuth v5 JWT with email/password credentials only, Tailwind CSS and Radix UI. Production is Vercel Hobby from GitHub main (redknot-rent-a-car-nine.vercel.app). The root layout is force-dynamic, so pages hit the database on every request.

Application shape: pages under src/app, mutations mainly as Server Actions (src/app/*/actions.ts), a small set of Route Handlers under src/app/api, domain logic in src/lib/services, RBAC in src/lib/permissions, navigation in src/lib/navigation, one Prisma client in src/lib/db. Desktop uses the existing left sidebar. Phones use a bottom tab bar (Dashboard, Rentals, Customers, Vehicles, More). The More sheet does not remove sidebar items.

- TiDB does not support Prisma interactive \$transaction (error P2028). Hire complete, payment, and settlement code already uses sequential writes.
- Dashboard and reports use Next.js unstable_cache with global keys. That is acceptable for one company. Do not add company-based cache keys in Phase 1.
- File uploads go to a local uploads/ folder, which is ephemeral on Vercel.
- Not present and must not be added in Phase 1: Company/tenant layer, Google OAuth, email verification, password reset, payment gateway, subscriptions, object storage, platform Super Admin UI.

B. Current Project Structure

Pages	src/app/**/page.tsx
Server actions	src/app/**/actions.ts (16 files)
API routes	src/app/api/**
Auth	src/lib/auth/, src/middleware.ts
RBAC	src/lib/permissions/index.ts
Services	src/lib/services/
Schema	prisma/schema.prisma
Navigation	src/lib/navigation/sidebar-items.ts
Tests	src/lib/services/business-logic.test.ts only

Desktop layout: left sidebar plus header. Phone layout: bottom tab bar. Both are part of the current product. The left sidebar structure must remain intact during Phase 1 polish.

C. Current Database Structure

Provider: MySQL / TiDB Cloud. No Company table. All business data belongs to this one deployment. UserRole enum is SUPER_ADMIN | ADMIN | EMPLOYEE | DRIVER. There is no MANAGER role. The seeded account manager@redknot.lk is role ADMIN.

Identity	User
Config	SystemSetting (global key/value)
Customers	Customer, CustomerDocument, CustomerBlacklist
Fleet	VehicleOwner, Vehicle, VehicleDocument, VehicleUnavailablePeriod, VehicleMaintenance, RatePlan
People	Driver, Broker
Hires	Rental, RentalHandover, RentalReturn, RentalDamage, RentalCharge
Money	Payment, SecurityDeposit, OwnerSettlement, BrokerCommission, DriverPayment, DriverExpense, Expense
Ops	Notification, AuditLog

Soft delete (deletedAt) is used on User, Customer, Vehicle, Owner, Driver, and Broker. Rentals are cancelled rather than soft-deleted.

Hard global unique fields: User.email, Customer.customerCode, Customer.nic, Driver.driverCode, Driver.nic, Vehicle.vehicleCode, Vehicle.registrationNumber, Rental.bookingNumber, Payment.paymentCode, Expense.expenseCode, maintenance and damage codes, owner/broker codes, SystemSetting.key. These will collide across companies later. Do not add companyId or change these uniques in Phase 1.

D. Current Authentication

File: src/lib/auth/index.ts. Credentials login compares email and password against User.password (bcrypt). Inactive and soft-deleted users are rejected. JWT session maxAge is 8 hours. Idle timeout is 10 minutes. JWT payload contains id, role, and lastActivity. There is no companyId. trustHost is true. The login page is /login. Middleware redirects unauthenticated users away from protected pages.

Login shows a generic “Invalid email or password” message. Empty required fields are blocked by the browser. After idle timeout the login page explains that the user was signed out after 10 minutes of inactivity.

- Not implemented: email verification, Google OAuth, password reset, magic links, 2FA, account logout, login rate limiting, Prisma Adapter Account/Session tables.
- Helpers: requireAuth(), requirePermission() (page redirect), requirePermissionApi() (JSON 401/403).
- Middleware matcher explicitly skips /api. Most receipt and document routes authenticate themselves. /api/health does not.
- JWT role and status are not re-read from the database on every request. A demotion or inactivation can linger until idle timeout or the 8-hour maxAge.

E. Current Role / Permission System

Enforcement is role mapped to permission strings (for example rentals.view). The sidebar hides items the role cannot see. Pages and almost all server actions call requirePermission. Hiding a button is not the only control, but there is no resource-level company check because this is still a single-tenant system.

SUPER_ADMIN	In-company System Administrator (admin@redknot.lk). All permissions including users.*
ADMIN	Seeded as “manager”. All permissions except users.view / users.create / users.edit
EMPLOYEE	Daily operations. Customers (no delete/blacklist), rentals, payments.create, damages, maintenance. No reports, expenses, settlements, settings, users, audit, or vehicle create
DRIVER	Login user, not linked to the Driver master record. Dashboard, rentals.view, and notifications only

- Today's SUPER_ADMIN is the company-level highest administrator, not a SaaS platform owner. That name must be split later: platform SUPER ADMIN versus company owner.
- ADMIN cannot manage staff. Only SUPER_ADMIN has users.* permissions.
- createUser / updateUser accept any role including SUPER_ADMIN. Anyone with users.create can mint another SUPER_ADMIN. Today only SUPER_ADMIN has users.create.
- Permission rentals.cancel exists in the RBAC list, but cancelRental actually uses rentals.edit. An Employee can therefore cancel a rental even without rentals.cancel.
- Do not implement future SaaS roles (PLATFORM_SUPER_ADMIN, COMPANY_OWNER, STAFF) in Phase 1.

F. Complete Current Left Sidebar / Navigation Map

Inspected source: src/lib/navigation/sidebar-items.ts. Every item below is part of the current product and must be preserved. Do not remove, shorten, merge, rename, or relocate any item without explicit approval.

1. Dashboard	/ · dashboard.view
2. Customers	/customers · customers.view
3. Vehicles	/vehicles · vehicles.view
4. Owners	/owners · owners.view
5. Drivers	/drivers · drivers.view
6. Brokers	/brokers · brokers.view
7. Rentals	/rentals · rentals.view · featured: true · MAIN badge — preserve
8. Payments	/payments · payments.view
9. Damages	/damages · damages.view
10. Settlements	/settlements · settlements.view
11. Maintenance	/maintenance · maintenance.view
12. Expenses	/expenses · expenses.view
13. Reports	/reports · reports.view

14. Notifications	/notifications · notifications.view
15. Audit Log	/audit · audit.view
16. Settings	/settings · settings.view
17. Users	/users · users.view · SUPER_ADMIN only

Extra routes that are not sidebar items but are still part of the product: /customers/blacklisted, /vehicles/documents, /vehicles/availability, /rentals/[id]/refund-deposit, /rentals/[id]/receipt, /rentals/record-ending-odometer.

UI polish may improve spacing, typography, icons, active/hover states, section grouping, scroll, width, collapsed state, and responsive behaviour. The navigation structure and functionality must remain intact.

G. Current Business Modules

- Dashboard: hire pipeline, today's/upcoming/active rentals, available vs hired vehicles, pending payments, revenue, expenses, alerts, notifications, optional AI summary.
- Customers: create, view, edit, search, documents/images, blacklist, blacklist history, export, delete/deactivate where currently supported.
- Vehicles: onboard with customer rate and owner rate, documents, availability, unavailable periods, maintenance, owner relationships.
- Owners / Brokers / Drivers: master data; driver payments and expenses; Driver login user is not linked to a Driver master row.
- Rentals / hires: inquiry, quote, confirm, assignment, handover, return, completion, extra KM, security deposit, refunds, damages, charges, payments, settlements.
- Payments: record, collect, settle deposit, refund deposit, history. EMPLOYEE has payments.create. Refund edit requires payments.edit.
- Damages: record, update, charge against hire.
- Settlements: owner payable, broker commission, PDFs, optional SMTP email.
- Maintenance: create and vehicle relationship; costs copied to expenses with a [MAINT: prefix so profit is not double-counted.
- Expenses: create only. Owner/broker payables are auto-logged on return/complete. Cash payouts are listed with [PROFIT:NO] so they do not double-count profit. There is no expense edit or delete action in the current code.
- Reports: rental, payment, expense, fleet utilization, profitability; PDF and CSV.
- Notifications, Audit Log, Settings, Users (SUPER_ADMIN only).

Settings keys currently include company_name, currency, currency_symbol, rental_day_start_time, default_included_km, block_blacklisted_booking, default_owner_commission, default_broker_commission. Some screens and formatCurrency() still hardcode "Rs." instead of using the settings symbol.

H. Current Rental / Hire Workflow

Implemented and must remain intact: Inquiry !' Quote !' Confirm !' vehicle/customer/driver assignment !' Handover !' Active !' Return (ending odometer and extra KM) !' Complete !' payments, deposit refund, damages, owner and broker settlements.

Pricing, extra KM, deposit remaining, payment balance, owner settlement, and broker commission live in `src/lib/services/pricing.ts`, `commission-calculator.ts`, `payment.ts`, `security-deposit.ts`, and `settlement.ts`. Do not change these formulas in Phase 1 unless a proven bug is identified and explicitly approved. Existing unit tests cover rental-day counting (19:00 boundary), extra KM, discount floor, balance floor, broker per-day/per-km versus flat fallback, and owner settlement when a vehicle pays an owner.

Accounting behaviour currently in production: when a hire is completed, customer `finalTotal` is income and the owner payable is expense. Pay-later only settles cash. Payables count in profit. Cash payouts are logged in Expenses but excluded from profit via `[PROFIT:NO]`. Complete rental and record payment no longer use TiDB interactive transactions.

I. Current Blacklist Functionality

This is a company-local blacklist. Do not convert it into the future global NIC blacklist during Phase 1.

- Flag on Customer (status `BLACKLISTED`, reason, date, user) plus append-only `CustomerBlacklist` history.
- Lookup is by customer record. NIC is unique on Customer, so lookup-by-NIC works inside this one database.
- Add/remove requires `customers.blacklist` (`SUPER_ADMIN` and `ADMIN` only, not `EMPLOYEE`).
- Booking uses `checkCustomerBlacklistWarning`. Optional hard block is controlled by setting `block_blacklisted_booking` (default `false`).
- Export of blacklisted customers requires `reports.export`.
- History is not silently deleted. Removal is a new history row with an action string.
- The future SaaS rule (warn, show reason, allow the company to continue, never hard-block) is not the current default behaviour. The current setting can still hard-block if turned on.

J. Functional Bugs Found

Confirmed in source or recent production history. Business formulas were not changed in this inspection.

- 1. `rentals.cancel` is unused. `cancelRental` goes through `rentals.edit`, so an Employee can cancel a hire.
 - 2. Broadcast notifications (`userId` null) share one `isRead` flag. If one user marks a broadcast as read, it becomes read for everyone.
 - 3. Print receipt page `/rentals/[id]/receipt` has no `requirePermission`. Middleware only requires login. Anyone with `rentals.view`, including `DRIVER`, can open any hire receipt by URL.
 - 4. `/api/health` is public and reports whether `AUTH_SECRET` is set, whether the database is connected, and Vercel environment details.
 - 5. JWT role/status can go stale until idle timeout or 8-hour `maxAge`.
 - 6. Uploads stored on the Vercel local disk do not survive deploys or restarts.
 - 7. `formatCurrency()` hardcodes "Rs." even though Settings stores `currency_symbol`.
 - 8. Code generators use `count()+1` and can race under concurrent creates.
 - 9. Expense has create only. There is no edit or delete action. Confirm whether this is intended.
 - 10. `DRIVER` login is not linked to a Driver master record, so a driver user is not scoped to assigned hires.
 - 11. Recently fixed in production and should remain: TiDB interactive transactions on complete/payment; missing expense logging for owner/broker payables; refund deposit hard to find; duplicate Held deposit rows after refund; Vercel Git deploys blocked unless the commit author is the Hobby-team GitHub owner.
-

No pricing, extra KM, deposit, payment, settlement, commission, or profit formula bug was proven in this inspection pass. Do not change those formulas unless a later test proves a defect and you approve the change.

K. Security Issues Found

- Seeded passwords are documented in seed data (including Admin@123).
- No login rate limit or account lockout.
- Public /api/health information leak.
- Receipt HTML page is under-authenticated relative to other hire pages.
- SUPER_ADMIN can be assigned in the user form by anyone with users.create (today only SUPER_ADMIN has that permission).
- Customer document download: any user with customers.view can fetch any document id.
- Settlement PDF APIs accept settlements.view or rentals.view, so a DRIVER who knows an id can download owner/broker PDFs.
- No multi-tenant isolation. That is expected for Phase 1 and must not be implemented yet.

L. IDOR / Authorization Risks

Inside this single company, any user who has a module permission can open any record in that module by changing the id. Examples: /customers/[id], /rentals/[id], receipt PDFs, customer document files. That is how the current single-tenant product is built. It is not cross-company IDOR yet, but it is exactly the pattern that becomes Company A reading Company B data unless every lookup later verifies company ownership.

- Role IDOR now: DRIVER with rentals.view can open any rental and any receipt by URL.
- Notification read-state: marking a global notification read affects all users.
- Do not implement companyId checks in Phase 1. Report only.

M. API / Server Action Issues

Almost all server actions call requirePermission. The exceptions and weaknesses below should be treated as targeted Phase 1 fixes if approved, not as a large refactor.

/api/health	No authentication
/rentals/[id]/receipt page	No permission check beyond login
checkCustomerBlacklistWarning	requireAuth only — any logged-in user
refreshSystemNotifications	requireAuth only
AI status / dashboard AI / reminder draft	requireAuth only
cancelRental	Uses rentals.edit instead of rentals.cancel
Settlement PDF APIs	settlements.view or rentals.view
Middleware	Matcher skips /api

N. Database Issues

- No tenant key. By design for Phase 1. Do not add Company or companyId yet.
- Customer.nic and Driver.nic are globally unique. That will block two companies from storing the same NIC later.
- Notification.userId is nullable and shares a single isRead flag. Wrong for broadcasts.
- CustomerBlacklist.action is an unconstrained String.
- Unique codes generated with count()+1 can race.
- Settings update still uses Prisma \$transaction, which has been historically fragile on TiDB.

Do not run migrations or change prisma/schema.prisma in Phase 1 unless a critical existing defect is identified and explicitly approved first.

O. Performance Issues

- Dashboard and reports cache with global keys. Fine for one company. Do not tenant-key the cache in Phase 1.
- Dashboard runs a large Promise.all of counts. Acceptable at current data size.
- Some detail pages use nested includes and may N+1 under load. Not proven as a current hotspot.
- Local images on Vercel fail more often than they are slow.
- Safe Phase 1 work: only obvious query or index cleanups that do not change business behaviour. No architecture rewrite.

P. UI/UX Issues

The target is a serious commercial Rent-a-Car Management System: professional, readable, comfortable for all-day use. Polish is allowed. Redesign of modules, removal of navigation, or change of business workflow is not allowed.

- Keep all 17 sidebar items and the MAIN badge on Rentals. Improve spacing, typography, icon consistency, active/hover states, grouping, scroll, width, collapsed state, and responsive behaviour.
- Keep the phone bottom tab bar and the desktop sidebar.
- Currency display is mixed: hardcoded “Rs.” versus Settings currency_symbol.
- Hire detail pages are dense (financial summary, mileage, deposits, settlements).
- Some tables remain cramped on small screens.
- Forms generally validate and toast errors, but required-field marking, double-submit guards, and empty/loading/error states are not fully consistent.
- Avoid excessive animation, gradients, decorative clutter, oversized cards, and heavy shadows.

Q. Deployment Issues

- Vercel Git deploys from main succeed only when the Git commit author is the Hobby-team GitHub owner (Randills96). Commits authored as another Git identity are blocked and never go live. Do not print secrets in this or any follow-up document.
- Required environment: DATABASE_URL, AUTH_SECRET, NEXTAUTH_URL.
- Uploads will not persist on the Vercel filesystem. Later SaaS work should move to S3/R2. Do not migrate storage in Phase 1.
- SMTP is optional. Settlement email is disabled until configured.
- OPENAI_API_KEY is optional for the dashboard AI summary.

R. Existing Tests

One automated test file: `src/lib/services/business-logic.test.ts`, run with `npm test`.

- Rental day counting, including same-day = 1 and the 19:00 multi-day boundary.
- Extra KM charge when over included allowance; no charge when within allowance; included KM scaled by days.
- Discount cannot drive finalTotal below zero.
- Outstanding balance never goes negative.
- Broker commission uses per-day and per-extra-km formula, with flat fallback when rates are zero.
- Owner settlement when the vehicle pays an owner.

There are no automated tests yet for permissions, authentication, deposits, expenses, or server actions.

S. Tests That Should Be Added

Add tests in Phase 1 where practical. Do not change formulas simply to make tests pass.

- Security deposit remaining / refunded / revise totals.
- Rental status machine (`canTransition`).
- Permission matrix: Employee cannot export reports or manage users; DRIVER cannot mutate hires.
- `cancelRental` must require `rentals.cancel` after that bug is fixed, if you approve the fix.
- Blacklist warning versus optional block setting.
- Payment balance and settlement remaining-amount guards.

T. Files That Require Changes

Only after approval. Typical Phase 1 files, not a rewrite:

- Layout, sidebar, header, tables, forms, badges, empty/loading/error states — visual polish only.
 - `src/app/rentals/[id]/receipt/page.tsx` — add permission check.
 - `src/app/api/health/route.ts` — lock down.
 - `src/app/rentals/actions.ts` — wire `cancel` to `rentals.cancel` if approved.
 - Notification read model/service — fix broadcast read-for-all.
 - `src/lib/utils/index.ts` `formatCurrency` plus a few labels — use settings symbol.
 - `src/lib/services/business-logic.test.ts` — extend coverage.
 - Do not change `prisma/schema.prisma` unless you approve a tiny notification-read fix.
-

U. Safe Changes for Phase 1

- Professional UI/UX polish with the existing design system. Keep every module and every sidebar item.
- Receipt page authentication and health-endpoint lock down.
- Wire cancelRental to rentals.cancel, if you approve that product rule.
- Fix broadcast notification read-for-all.
- Currency display from settings (display only, not a calculation change).
- Double-submit guards and clearer form/error feedback.
- Expand unit tests around existing formulas and permissions.
- Document the Vercel upload limitation. Do not migrate to S3/R2 yet.

V. Changes That Must Wait for SaaS Phase

- Company / tenant architecture and companyId on rows.
- Platform SUPER ADMIN dashboard and separate platform sidebar.
- Subscriptions, renewal payments, grace period, suspension.
- Google login, email verification, password reset.
- Global NIC blacklist across companies.
- S3/R2 or other object storage migration.
- Dynamic per-company branding (name, logo, invoice, currency as tenant data).
- Cache keys by companyId.
- Replacing Prisma, Next.js, the auth library, or the current database.

W. Future SaaS Architecture Considerations

Do not implement these now. They are recorded so Phase 1 work does not paint the later conversion into a corner.

- Shared TiDB plus companyId on tenant rows, with a Prisma query filter. MySQL/TiDB has no Postgres-style RLS.
 - One user belongs to one company only.
 - Platform SUPER ADMIN has companyId null and a completely separate UI. It must not reuse the company Rent-a-Car sidebar.
 - Company Owner should receive the same major business functionality as today's company-level highest administrator, including the current left sidebar modules.
 - Staff handle daily operations. They should not see owner-level revenue/profit reports, staff management, subscription, ownership, or platform administration.
 - Global blacklist is the intentional cross-company exception. Primary business lookup is NIC. Technical primary key remains a generated id. Warn on hire; do not hard-block.
 - Subscription amounts (currently about LKR 85,000 initial and LKR 20,000 renewal) must be configurable by platform Super Admin, not hardcoded. Bank transfer; platform Super Admin marks paid. Data must never be deleted on expiry.
 - Hard-coded RedKnot branding (layout title, login card, sidebar "RedKnot", some PDF/email copy, formatCurrency Rs.) must later become the logged-in company's branding. Keep RedKnot branding functional in Phase 1.
-

X. Potential Breaking Changes

Even Phase 1 “safe” fixes can change daily behaviour. None of the following will be applied until you confirm.

- Employee loses the ability to cancel a hire if cancel is restricted to rentals.cancel.
- Tightening receipt access may stop DRIVER from opening hire receipts by URL.
- Fixing broadcast notifications will make unread counts per-user again; some users will see alerts they previously marked read via another user.
- Locking /api/health will break any unauthenticated uptime check that currently hits it.
- Changing formatCurrency to settings-driven display may change how amounts look if currency_symbol is not “Rs.”.
- Later SaaS work (not Phase 1) will break global unique NIC/registration/booking numbers, global settings, global cache keys, and today's SUPER_ADMIN meaning.

Y. Recommended Phase 1 Implementation Order

- 1. You review this report and answer the decisions below.
- 2. Security nits: health endpoint, receipt page permission, cancel permission if approved.
- 3. Broadcast notification read bug.
- 4. Professional UI/UX polish pass. Do not remove modules or sidebar items.
- 5. Expand unit tests for calculations and permissions. Do not change formulas to make tests pass.
- 6. Manual QA on production after a deploy whose Git commit author is Randills96.
- 7. Git checkpoint = stable single-tenant baseline.
- 8. Only then begin Phase 2 SaaS architecture.

This document is inspection only. No application files were modified, no packages were installed, no database migrations were run, and no SaaS features were created as part of this review. Implementation starts only after your written approval.

Questions waiting for your decision

Please answer these before Phase 1 implementation begins. Paste your answers in chat after you have reviewed this PDF.

- 1. Proceed with the safe Phase 1 list in section U (UI polish, receipt/health auth, notification read fix, currency display, tests)?
 - 2. Should Employee cancel be blocked so only users with rentals.cancel can cancel a hire?
 - 3. Should DRIVER keep access to all hire receipts by URL, or should receipt access be tightened?
 - 4. Should Phase 1 add expense edit/delete, or leave expenses as create-only as they are today?
-

Prepared 17 Sep 2026 · No code or schema was changed for this review

Prepared 17 Sep 2026 · No code or schema was changed for this review

Prepared 17 Sep 2026 · No code or schema was changed for this review

Prepared 17 Sep 2026 · No code or schema was changed for this review

Prepared 17 Sep 2026 · No code or schema was changed for this review

Prepared 17 Sep 2026 · No code or schema was changed for this review

Prepared 17 Sep 2026 · No code or schema was changed for this review

Prepared 17 Sep 2026 · No code or schema was changed for this review

Prepared 17 Sep 2026 · No code or schema was changed for this review

Prepared 17 Sep 2026 · No code or schema was changed for this review

Prepared 17 Sep 2026 · No code or schema was changed for this review

Prepared 17 Sep 2026 · No code or schema was changed for this review

